

MANUAL MAESTRO DE ARQUITECTURA, CORRELACIÓN MULTIFUENTE, MITRE ATT&CK; Y DESPLIEGUE

ESPECIFICACIONES DEL DOCUMENTO MAESTRO

Sistema: Cyrvanta SOC & Security Response Governance Platform (v1.0 Master Enterprise Edition)
Arquitectura: Clean Architecture, Monolito Modular, Ports & Adapters, PostgreSQL RLS
Taxonomía de Amenazas: Mapeo Nativo MITRE ATT&CK; Framework & TTPs
Motor de Correlación: Determinista Multifuente (Wazuh SIEM, OpenSearch, Syslog, Time-Windowing)
Gobernanza: Principio de 4-Ojos (Dual Control), Auditoría Inmutable, Rollback Reactivo
Fecha de Emisión: Agosto de 2026

RESUMEN EJECUTIVO Y OBJETIVOS DE LA PLATAFORMA

Cyrvanta es una solución integral de Respuesta Automatizada y Gobernanza de Ciberseguridad diseñada para Centros de Operaciones de Seguridad (SOC) de alta exigencia. El sistema garantiza la detección temprana de amenazas, la correlación determinista multifuente de eventos, el mapeo contra la taxonomía mundial MITRE ATT&CK; la evaluación determinista del riesgo, la contención supervisada bajo el principio de 4-Ojos, y la trazabilidad absoluta de cada acción realizada por los analistas. Este manual detalla de punta a punta sus contenedores, pantallas, motor de correlación, framework MITRE, estrategias de integración y guías de operación en vivo.

Capítulo 1: Introducción y Arquitectura General de Cyrvanta

Cyrvanta se estructura sobre el patrón de **Clean Architecture y Puertos y Adaptadores (Hexagonal Architecture)**. Esta decisión de diseño independiza completamente el núcleo del dominio y la lógica de negocio de las tecnologías de infraestructura externa (tales como bases de datos, conectores SIEM, motores de IA o gateways de correo).

1.1 Principios Fundamentales de Diseño

- **Seguridad y Aislamiento Multitenant Estricto:** Cada organización o tenant opera de manera aislada. A nivel de base de datos, PostgreSQL aplica *Row Level Security (RLS)*, garantizando que ninguna consulta SQL o mutación pueda cruzar datos entre clientes distintos.
- **Gobernanza de Respuesta y Principio de 4-Ojos (Dual Control):** Para evitar acciones unilaterales de contención o modificaciones maliciosas de seguridad, las acciones críticas requieren que un 1er analista genere la propuesta de respuesta y un 2º analista independiente autorice y firme la solicitud antes de ser ejecutada por el sistema.
- **Auditoría Inmutable y No Repudio:** Toda mutación, inicio de sesión, propuesta, aprobación o rollback genera registros inmodificables con estampilla de tiempo exacta (UTC), identificador único de usuario (email) y dirección IP de origen.
- **Explicaciones Grounded Deterministas e IA Supervisada:** El sistema genera evaluaciones de riesgo e interpretaciones basadas en datos deterministas comprobados. Si se integra un motor de IA como Ollama (Gemma 4), la IA actúa únicamente como redactora supervisada de estilo, sin autorizar ni tomar decisiones de seguridad por sí sola.
- **Soporte Bilingüe Nativo (i18n):** Toda la interfaz de usuario, respuestas de la API REST, eventos de auditoría y notificaciones disponen de soporte nativo en español e inglés.

Capítulo 2: Arquitectura de Contenedores Docker y Redes

El ecosistema de Cyrvanta se despliega mediante contenedores Docker interconectados a través de una red aislada (cyrvanta_net). A continuación se especifica la responsabilidad técnica de cada contenedor, su puerto de servicio y su impacto directo en el Dashboard y menú del usuario:

Contenedor	Puerto / Red	Función Técnica en la Arquitectura	Impacto / Rol en la Interfaz Web
cyrvanta-reverse-proxy	8080 (TCP) Público	Proxy inverso Nginx que termina SSL/TLS, enruta el tráfico web a React y las peticiones REST al Backend FastAPI.	Es el punto de acceso principal del usuario al navegar en http://localhost:8080 .
cyrvanta-frontend	80 (TCP) Interno	Servidor web sirviendo la SPA compilada en React, TypeScript y Vite con estilos CSS puros e i18n.	Renderiza visualmente todos los menús, componentes, modales y tarjetas.
cyrvanta-backend	8000 (TCP) Exposición REST	Servidor FastAPI con la lógica de negocio, validaciones Pydantic v2, motor de correlación y APIs de respuesta.	Procesa las peticiones AJAX/REST de todas las acciones del usuario.
cyrvanta-postgres	5432 (TCP) Interno	Base de datos relacional PostgreSQL 16 con RLS (Row Level Security) para el registro autoritativo.	Almacena de forma inmutable usuarios, incidentes, bitácora y auditoría.
cyrvanta-redis	6379 (TCP) Interno	Almacenamiento en memoria Redis 7 para caché de tokens JWT, control de rate-limiting y sesiones.	Garantiza la respuesta instantánea en autenticación y navegación.
cyrvanta-rabbitmq	5672 (TCP) Interno	Broker de mensajes para procesamiento asíncrono y desacoplamiento de eventos de dominio.	Permite procesar cargas masivas de alertas sin bloquear la interfaz.

cyrvanta-worker / scheduler	Interno a cyrvanta_net	Procesadores de fondo que ejecutan tareas asíncronas, recalculan vectores de riesgo y sincronizan estados.	Actualizan en tiempo real los indicadores y topologías del Dashboard.
cyrvanta-opensearch	9200 (TCP) Interno	Motor de indexación masiva de logs de telemetría de alto volumen y búsqueda de evidencias.	Alimenta el buscador de logs y evidencias en el menú <i>Alertas</i> .
cyrvanta-wazuh-manager	1514-1515 Interno/Ext	Servidor SIEM Wazuh que recopila eventos de agentes de seguridad instalados en hosts y servidores.	Puebla automáticamente las alertas entrantes en el menú <i>Alertas</i> .
cyrvanta-n8n	5678 (TCP) Opcional	Motor de orquestación de workflows externos opcionales para integración con sistemas de terceros.	Ejecuta bindings adicionales en el menú <i>Playbooks</i> .

Capítulo 3: Manual de Navegación y Operación de las Pantallas del Menú

A continuación se realiza una explicación detallada de cada una de las 9 secciones del menú lateral de Cyrvanta, sus componentes visuales y las acciones que el analista puede ejecutar en ellas:

3.1 ■ Resumen (Dashboard Principal)

Es la pantalla de inicio ejecutiva del SOC. Presenta una visión panorámica e interactiva de la postura de seguridad:

- **Infraestructura SOC & Direcciones IP Conectadas:** Panel interactivo en formato de tarjetas que visualiza la topología de red de Cyrvanta (Gateway NGINX, FastAPI, PostgreSQL, SIEM Wazuh) junto a los nodos perimetrales del laboratorio (Firewall Palo Alto y Active Directory).
- **Métricas de Riesgo y Salud:** Muestra el puntaje de riesgo global, incidentes críticos activos y el estado de salud de los servicios.
- **Bitácora Reciente:** Despliega los últimos eventos auditados en tiempo real.

3.2 ■ Incidentes (Centro de Gestión y Respuesta)

Es la consola central de respuesta ante amenazas. Al seleccionar un incidente (ej. DEMO-CRED-001), el analista accede a:

- **Resumen & Causa Raíz:** Explicación determinista de los vectores de ataque correlacionados y nivel de prioridad.
- **Matriz de Reclamos (Claims):** Evaluación de certezas e incertidumbres del incidente.
- **■ Proponer Respuesta Segura:** Permite proponer la ejecución de un Playbook de contención (ej: simulate-user-block). Una vez propuesta, el botón se deshabilita para evitar duplicaciones.
- **Flujo de Aprobación 4-Ojos:** Si el incidente requiere aprobación, se visualiza el estado AWAITING_APPROVAL. Un 2º analista autenticado puede aprobar o rechazar la acción. Al aprobarse, el progreso cambia a **2/2 ✓ Aprobado por 4-Ojos**.
- **■ Deshacer / Rollback (Restaurar Acceso):** Permite revertir la contención en caso de falso positivo. Al presionarse, se reactiva el usuario (is_active = true) y el botón cambia reactivamente a estado deshabilitado en verde con la confirmación **✓ Rollback Ejecutado — Acceso Restaurado**.
- **Historial de Ejecución:** Registro inmutable de propuestas, firmas 4-Ojos y ejecuciones de rollback con la atribución explícita del usuario que la accionó.

3.3 ■ Alertas (Consola de Ingesta y Triage)

Consola dedicada a la telemetría de eventos recibidos desde Wazuh SIEM y OpenSearch:

- **Filtros de Triage:** Clasifica las alertas en UNREVIEWED (Sin revisar), RELEVANT (Relevante) o DISCARDED (Descartada).
- **Detalle Forense:** Muestra IPs de origen y destino, categoría de la regla SIEM, severidad y vinculación al incidente correlacionado.

3.4 ■ Playbooks (Librería de Automatización)

Módulo de gestión de procedimientos de respuesta automatizada:

- **Librería Nativa por Defecto:** Incluye playbooks nativos pre-construidos para bloqueo de usuarios, aislamiento de hosts, notificación de incidentes críticos y creación de tickets ITSM.
- **Binding Opcional a n8n:** Permite vincular opcionalmente una acción nativa a un workflow de n8n mediante claves de binding.

3.5 ■ Integraciones (Biblioteca de Conectores)

Centro de configuración y prueba de conectividad con tecnologías de terceros:

- **Modales de Configuración y Test:** Permite ingresar URLs y claves API para Wazuh, OpenSearch, MISP, Ollama AI (Gemma 4), n8n, ServiceNow y SMTP Lab.
- **Conectores Empresariales (EDR / Firewalls):** Incluye los adaptadores para Microsoft Defender, CrowdStrike Falcon, SentinelOne, Palo Alto PA Firewall y Fortinet FortiGate. Cada tarjeta incluye botones para ingresar credenciales o ejecutar pruebas de conexión en vivo.

3.6 ■ Memoria Gobernada (Aprendizaje Supervisado)

Gestión del conocimiento acumulado del SOC:

- **Lecciones Aprendidas & Candidatas:** Registro supervisado de patrones y hallazgos clave.
- **Filtro Sintético Bloqueado:** Permite etiquetar lecciones sintéticas o de prueba como bloqueadas para garantizar que no alteren las decisiones en producción.

3.7 ■ Llaves API (Puesta en Escena Staging)

Módulo de administración de llaves de acceso para la integración segura con n8n y servicios de comunicación interna, separando las llaves activas de las llaves restringidas a metadatos.

3.8 ■ Auditoría (Trazabilidad e Inmutabilidad)

Bitácora oficial de cumplimiento y auditoría de seguridad:

- **Trazabilidad por Fila:** Muestra el resultado (SUCCESS/FAILURE), la acción ejecutada, la fecha/hora UTC, el email explícito del analista ejecutor (ej: ■ demo@cyrvanta.uy) y la dirección IP de origen de la solicitud (ej: ■ 127.0.0.1) alineados horizontalmente en una misma fila.

3.9 ■■ Administración (Multitenant & Directorio LDAP)

Panel de control administrativo de la plataforma:

- **Gestión de Usuarios y Roles:** Permite crear analistas, asignar roles (tenant-admin, analyst, auditor) y gestionar permisos de acceso.
- **Configuración LDAP / Active Directory:** Configuración del servidor de dominio corporativo (Servidor URI, Base DN, Bind DN, StartTLS) con mapeo dinámico de grupos de Active Directory a roles de Cyrvanta y aprovisionamiento JIT (Just-In-Time).

Capítulo 4: Caso de Uso Normal Operativo (Flujo de Trabajo del SOC)

1. Detección e Ingesta de Alertas

Un atacante intenta autenticarse repetidamente vía SSH en un servidor interno. El agente Wazuh detecta los fallos de autenticación (Regla #5710) y envía la telemetría a Cyrvanta. La alerta aparece listada en el menú **Alertas** en estado UNREVIEWED.

2. Correlación y Creación del Incidente

El motor de correlación de Cyrvanta agrupa las alertas asociadas al host e identidad afectada, creando de forma automática el incidente DEMO-CRED-001 con severidad **HIGH** y prioridad 2.

3. Evaluación Forense y Propuesta de Respuesta

El Analista SOC 1 (demo@cyrvanta.uy) ingresa al incidente en el menú **Incidentes**, revisa la causa raíz y presiona el botón **■ Proponer Respuesta Segura** para ejecutar el playbook simulate-user-block. El sistema genera una propuesta formal y deshabilita el botón de propuesta para evitar duplicados.

4. Gobernanza 4-Ojos y Firma del Segundo Analista

Debido a las políticas de seguridad, la acción entra en estado Awaiting_Approval. Un Analista SOC 2 independiente (ldap-demo@cyrvanta.uy) ingresa al sistema, examina la propuesta y presiona **✓ Aprobar Respuesta**. El progreso se actualiza inmediatamente a **2/2 ✓ Aprobado por 4-Ojos**.

5. Ejecución Automatizada de Contención

Al recibir la doble autorización, el Backend ejecuta la contención desactivando la cuenta del usuario objetivo (synthetic-demo-user@cyrvanta.uy), cambiando su estado a is_active = false en PostgreSQL.

6. Investigación Forense y Detección de Falso Positivo

Posteriormente, los analistas comprueban que el tráfico pertenecía a una prueba programada autorizada (Falso Positivo). El Analista SOC 1 presiona el botón **■ Deshacer / Rollback (Restaurar Acceso)** en la tarjeta del incidente.

7. Reversión, Actualización Reactiva y Auditoría

El backend reactiva de inmediato la cuenta (is_active = true). En la interfaz React, el botón de rollback pasa reactivamente a deshabilitado en verde (**✓ Rollback Ejecutado — Acceso Restaurado**) y se registra una entrada inmutable en el menú **Auditoría** con el email demo@cyrvanta.uy e IP 127.0.0.1. Se realiza una prueba de login demostrando respuesta exitosa 200 OK.

Capítulo 5: Guía de Despliegue en Producción y Preguntas Frecuentes de Infraestructura

5.1 ¿Debo instalar todos los contenedores al poner el sistema en producción?

No necesariamente todos. Los contenedores del núcleo (Backend, Frontend, Reverse-Proxy, Postgres, Redis, RabbitMQ, Worker y Scheduler) son obligatorios para el funcionamiento de Cyrvanta. Los contenedores de telemetría (OpenSearch y Wazuh Manager) o de automatización (n8n) son opcionales: si el cliente ya posee su propia infraestructura de SIEM (Wazuh/OpenSearch) o su propio clúster de n8n, se deshacen los contenedores locales y se conecta Cyrvanta directamente a los servidores existentes del cliente mediante la configuración de red.

5.2 ¿El sistema detecta automáticamente los nodos de la red del cliente o se configuran uno a uno?

Funciona mediante un modelo Híbrido:

- **Detección Automática de Telemetría:** Los dispositivos de red, servidores y computadoras que envían logs al SIEM son detectados e ingestados **automáticamente** por Cyrvanta a medida que se generan eventos, construyendo el mapa de activos e IPs sin configuración manual nodo por nodo.
- **Configuración Única de Servicios:** Para ejecutar acciones de respuesta (Firewalls, EDRs, Active Directory), no se ingresa nodo por nodo. Se realiza **una sola configuración centralizada por tipo de servicio** en el menú *Integraciones* (API Key del Firewall/EDR) o *Administración* (URI del Active Directory).

5.3 ¿Cómo ejecuta un Playbook Cyrvanta sobre un nodo detrás de un Firewall Palo Alto? ¿Lo bloquearía?

Cyrvanta no realiza 'ataques' directos ni escaneos no autorizados a través del Firewall. Acciona mediante dos vías seguras:

1. **Vía API REST de Gestión del Firewall:** Cyrvanta envía una solicitud HTTPS REST autenticada al puerto de administración de Palo Alto. Es el propio Palo Alto quien ejecuta el bloqueo perimetral.
2. **Vía Agente EDR / SIEM Local (Wazuh, Defender, CrowdStrike):** El agente instalado en el nodo interno recibe la orden a través de su canal de gestión saliente TLS existente.

¿El Firewall lo bloquearía? NO, porque la IP del servidor Cyrvanta está en la lista blanca de la interfaz de administración (Management Plane) con tokens de API autorizados previamente.

5.4 ¿Cuál es el estado de los conectores empresariales (Palo Alto, Defender, CrowdStrike, ServiceNow)?

El 90% del desarrollo de integración está 100% terminado. Todas las clases Python, esquemas de datos, almacenamiento encriptado de API Keys, formularios modales del frontend y pruebas de conexión están desarrollados. En esta versión inicial responden en modo simulado seguro.

Al conectar una tecnología real en producción, únicamente se completan las ~15 líneas de llamada REST `httpx.post(...)` específicas de la versión API que tenga contratada el cliente. No se requiere rehacer la arquitectura ni la interfaz.

5.5 ¿Es necesario respaldar los contenedores? ¿Cómo se debe hacer y qué guarda Git?

Diferencia clave entre Git y Datos de Producción:

- **Lo que guarda Git (Código e IaC):** Cuando ejecutas git commit y git push, respaldas únicamente el código fuente (Python/React), las recetas de construcción (Dockerfile), la infraestructura como código (docker-compose.yml), configuraciones base y documentación. **Git NO guarda la base de datos viva ni la telemetría.**
- **Naturaleza Efímera de Contenedores:** Los contenedores Docker son por definición efímeros (*stateless*). No se respaldan los contenedores vivos: si uno falla, Docker lo destruye y crea uno idéntico en 2 segundos desde las recetas de Git.
- **Respaldo de Volúmenes Persistentes (Docker Data Volumes):** Lo que verdaderamente se respalda en producción son los volúmenes de datos:
 1. postgres_data: Base de datos PostgreSQL (usuarios, incidentes, playbooks, auditoría).
 2. opensearch_data: Índices y telemetría histórica del SIEM.
 3. wazuh_data: Reglas y llaves de agentes de endpoints.
 4. n8n_data: Credenciales y flujos de n8n.
- **Estrategia de Producción:** En clientes reales se aplica un script cron nocturno de exportación de base de datos (pg_dumpall) enviado a un almacenamiento externo seguro (S3 / NAS) junto a snapshots periódicos del disco del servidor.

5.6 Proyección de Cuellos de Botella, Canales de Saturación y Estrategias de Escalamiento

Análisis de Capacidad y Mitigación de Desempeño bajo Alta Carga Corporativa:

- **1. Ingesta de Telemetría e I/O de Disco (OpenSearch / PostgreSQL):** Ráfagas de miles de eventos/seg (EPS) pueden saturar los IOPS de disco. *Solución:* CQRS estricto (telemetría cruda en OpenSearch, control en Postgres), políticas ILM de rotación de índices (>90 días a S3) y discos SSD/NVMe.
- **2. Procesamiento de Tareas Asíncronas (RabbitMQ / Workers):** Escaneos masivos pueden generar retraso de tareas (*Worker Lag*). *Solución:* Escalamiento horizontal de réplicas de worker (docker compose up --scale worker=5) y deduplicación por ventana temporal.
- **3. Inferencia de Inteligencia Artificial (Ollama / Gemma 4):** Múltiples explicaciones simultáneas pueden agotar la VRAM/CPU. *Solución:* Invocación 100% asíncrona no bloqueante, servidor Ollama en GPU dedicada (NVIDIA RTX/A100) y caché de respuestas en Redis.
- **4. Concurrencia de Conexiones de Base de Datos (PostgreSQL RLS):** Decenas de analistas consultando el Dashboard en paralelo. *Solución:* Pooling con PgBouncer y Réplicas de Lectura (*Read Replicas*).

Capítulo 6: Análisis Estratégico de Integraciones y Licenciamiento en Clientes

Un aspecto crucial al comercializar e instalar Cyrvanta en entornos corporativos reales es adaptar la conectividad a la infraestructura existente del cliente sin obligarlo a incurrir en costos extras innecesarios de licencias. A continuación se presenta la matriz estratégica de decisión para las tecnologías más comunes:

6.1 Estrategia de Conexión con Microsoft Defender & Windows Endpoints

Escenario A — Cliente con SIEM Corporativo Existente (Wazuh, Splunk, Elastic, Sentinel):

- **Instalación en PCs:** NO se instala ningún agente en las computadoras de los empleados.
- **Conexión:** Cyrvanta se conecta directamente al SIEM del cliente por API REST. El SIEM del cliente ya recopila los eventos de Defender y los entrega a Cyrvanta.
- **Costo de Licencia:** \$0 adicional.

Escenario B — Cliente con Licencias Microsoft Cloud Enterprise (M365 E5 / Defender for Endpoint / Azure Entra ID):

- **Instalación en PCs:** NO se instala software en las PCs.
- **Conexión:** Cyrvanta se conecta por HTTPS a la API nativa **Microsoft Graph Security API**.
- **¿Requiere compra de licencias? NO.** Si la empresa ya paga licencias empresariales de Microsoft, el acceso a la Graph API ya está incluido en su suscripción previa.

Escenario C — Cliente sin SIEM ni Licencias Nube de Microsoft (Infraestructura Tradicional / On-Premise / Pyme):

- **Instalación en PCs:** Sí. Se despliega el **Agente de Wazuh** en las computadoras.
- **Método de Despliegue Masivo:** No se instala computadora por computadora. El administrador ejecuta una **Directiva de Grupo (GPO) en Active Directory** que instala el agente en segundo plano a todas las computadoras en minutos.
- **Costo de Licencia: \$0.** El agente de Wazuh es Open Source y gratuito.

Matriz Comparativa de Decisión de Despliegue EDR / SIEM:

Infraestructura del Cliente	Solución Recomendada en Cyrvanta	¿Agentes en PCs?	Costo de Licencias
Tiene SIEM existente	Conectar Cyrvanta al SIEM por API REST	NO	\$0 Extra
Tiene Microsoft 365 E5 / Defender Cloud	Conectar a Microsoft Graph Security API	NO	\$0 Extra (Incluido en M365)
No tiene SIEM ni Cloud M365	Desplegar Agente Wazuh OpenSource vía GPO	SÍ (Automático por GPO)	\$0 Extra (Open Source)

Capítulo 7: Marco MITRE ATT&CK; y Motor de Correlación Multifuente de Alertas

Cyrvanta incorpora un motor de **Correlación Determinista Multifuente** integrado de forma nativa con la taxonomía estándar global **MITRE ATT&CK; Framework**. Esta arquitectura transforma eventos aislados de red en un modelo estructurado de amenazas comprensible y altamente accionable para el analista SOC.

7.1 Motor de Correlación Determinista Multifuente (Time-Windowing Engine)

El problema principal de los SOC's modernos es la *fatiga de alertas (Alert Fatigue)*. Un solo ataque brute force puede generar miles de entradas individuales de log en pocos minutos. El motor de correlación de Cyrvanta resuelve esto mediante:

- **Agrupamiento por Ventana Temporal (Time-Windowing):** Agrupa automáticamente eventos e ingestas de telemetría provenientes de Wazuh SIEM, OpenSearch y Syslogs ocurridos dentro de una ventana de tiempo configurable.
- **Agregación por Entidad de Dominio:** Modela los eventos según la entidad afectada (Dirección IP de origen/destino, Nombre de usuario en Active Directory, Hash de ejecutable o Nombre de Host).
- **Deduplicación y Filtrado Inteligente:** Elimina registros redundantes y clasifica la telemetría en estados de triaje: UNREVIEWED (Sin revisar), RELEVANT (Relevante para incidente) o DISCARDED (Ruido o falso positivo).
- **Unificación en Incidente Correlacionado:** Reúne múltiples alertas individuales en un único **Incidente de Seguridad Unificado** con nivel de severidad (Critical, High, Medium, Low) y puntaje de prioridad (1 a 5).

7.2 Integración con el Framework MITRE ATT&CK;

Cada alerta, incidente y playbook en Cyrvanta está etiquetado deterministamente con los códigos de técnica oficiales de MITRE ATT&CK; (Tactic & Technique TTPs):

Código TTP MITRE	Táctica / Nombre de Técnica	Descripción y Uso en Cyrvanta	Playbook Nativo Asociado
T1078	Defense Evasion / Valid Accounts	Uso de credenciales comprometidas o legítimas para acceso no autorizado.	simulate-user-block
T1110	Credential Access / Brute Force	Intentos repetidos de autenticación en SSH, RDP o Active Directory.	simulate-user-block
T1059	Execution / Command & Scripting Interpreter	Ejecución de scripts maliciosos PowerShell, Bash o CMD en endpoints.	simulate-host-isolation
T1021	Lateral Movement / Remote Services	Desplazamiento lateral entre servidores internos mediante SMB/WinRM.	simulate-host-isolation
T1486	Impact / Data Encrypted for Impact	Actividad de Ransomware cifrando archivos en discos o compartidos.	simulate-critical-incident-notification
T1071	Command & Control / Application Protocol	Tráfico de C2 enviando datos por HTTPS/DNS no autorizado.	simulate-itsm-ticket-creation

7.3 Explicación Determinista del Riesgo e Impacto MITRE

Al inspeccionar un incidente en el menú **Incidentes**, el motor de exposición de Cyrvanta calcula deterministamente las tácticas MITRE involucradas (*Initial Access, Execution, Persistence, Privilege Escalation, Credential Access, Lateral Movement, Impact*) y genera una explicación fundada (*grounded*) indicando exactamente qué técnica MITRE neutralizará el Playbook propuesto, garantizando que el analista entienda la efectividad de la respuesta antes de solicitar la firma de 4-Ojos.

Capítulo 8: Control de Acceso Basado en Roles (RBAC) y Memoria Gobernada

Cyrvanta implementa un modelo de seguridad por diseño (*Security by Design*) basado en el **Control de Acceso Basado en Roles (RBAC)** estricto y una **Arquitectura de Memoria Gobernada (Human-in-the-Loop)**. Este capítulo detalla la matriz de permisos para cada tipo de usuario y el funcionamiento del motor de aprendizaje continuo.

8.1 Matriz de Roles y Control de Acceso (RBAC)

El acceso a la plataforma está regulado según tres perfiles principales con aislamiento multitenant estricto en la capa de datos:

Perfil / Rol	Nombre en Sistema	Funcionalidades y Menús Permitidos	Derechos de Firma y Gobernanza
Administrador del SOC / CISO	admin / SOC_ADMIN	Acceso total: Integraciones (Wazuh, EDR, Firewall, LDAP), Usuarios, Llaves API, n8n, Memoria Gobernada, Auditoría.	Firma de 2da autorización en Principio de 4-Ojos . Configuración global de gobernanza.
Analista de Seguridad SOC	analyst / SOC_ANALYST_L2	Dashboard, Pulso Operativo, Topología de Red, Centro de Incidentes, Triage, Análisis IA (Gemma 4), Propuesta de Playbooks.	Firma de 1ra autorización (1 Ojo). Proponer contenciones y ejecutar Rollbacks.
Auditor de Cumplimiento	auditor / COMPLIANCE_AUDITOR	Solo Lectura (Read-Only): Registro de Auditoría inmutable, Descarga de Reportes HTML/PDF, Consulta de Memorias.	Sin permisos de ejecución o firma. Perfil de supervisión AGESIC / ISO 27001.

8.2 Arquitectura de Memoria Gobernada (Human-in-the-Loop)

La **Memoria Gobernada (*Governed Memory*)** es el motor de aprendizaje institucional de Cyrvanta. A diferencia de los sistemas de IA no controlados que modifican reglas de forma autónoma con riesgo de alucinación o envenenamiento (*Data Poisoning*), Cyrvanta aplica el principio **Human-in-the-Loop (Humano al Mando)**:

- 1. Propuesta de Lección Aprendida (Memory Candidate):** Al resolver incidentes o triajar falsos positivos, la IA o el analista proponen un candidato de memoria (ej. 'Tráfico del script backup_sync.ps1 a las 02:00 AM es actividad autorizada').
- 2. Trazabilidad de Origen (Provenance):** Cada memoria registra su procedencia inmutable (ID de incidente correlacionado, usuario creador y timestamp).
- 3. Gobernanza y Evaluación Humana:** La memoria permanece en estado PROPOSED o IN_REVIEW hasta que un analista o Administrador la aprueba (APPROVE), rechaza (REJECT) o solicita ajustes.
- 4. Activación e Inmutabilidad (Active Memory):** Al ser aprobada, pasa a estado ACTIVE y enriquece de inmediato el motor de correlación para suprimir falsos positivos automáticamente.
- 5. Retroalimentación de Efectividad:** Mide continuamente la tasa de efectividad (ACTION_EFFECTIVE, FALSE_POSITIVE) permitiendo desactivar lecciones obsoletas sin borrar su historial.

8.3 Taxonomía Oficial de Gobernanza por Playbook

Cada playbook registrado en la biblioteca posee una modalidad de aprobación real alineada con su nivel de impacto operacional:

Código del Playbook	Nombre del Playbook	Modo de Gobernanza Real	Justificación Operativa / SecOps
---------------------	---------------------	-------------------------	----------------------------------

simulate-user-block	Simular bloqueo de usuario / Cuenta comprometida	■ FOUR_EYES (4 Ojos)	Contención crítica de identidad: requiere 2 firmas independientes antes de desactivar la cuenta en LDAP/PostgreSQL.
simulate-host-isolation	Aislamiento de host / Endpoint comprometido	■ FOUR_EYES (4 Ojos)	Corte de red EDR: requiere 2 firmas para aislar un servidor o workstation de producción.
lateral-movement	Movimiento lateral entre nodos	■ FOUR_EYES (4 Ojos)	Interrupción de tráfico SMB/WinRM entre servidores críticos.
privilege-escalation	Escalamiento de privilegios anómalo	■ FOUR_EYES (4 Ojos)	Revocación de permisos de cuenta privilegiada o dominio.
security-control-disabled	Desactivación de controles de seguridad	■ FOUR_EYES (4 Ojos)	Reactivación forzada de agentes EDR/Logs ante posible evasión.
simulate-critical-incident-notification	Notificación de incidente crítico	■ SINGLE (Simple)	Despacho de notificaciones por SMTP, Teams o Slack (1 firma).
simulate-itsm-ticket-creation	Creación de ticket ITSM (ServiceNow/Jira)	■ SINGLE (Simple)	Apertura de tickets de incidente SecOps (1 firma).
automated-enrichment	Enriquecimiento automático de incidentes	■ AUTOMATIC	Recolección de contexto e indicadores sin alteración de infraestructura.
evidence-preservation	Preservación de evidencia e inmutabilidad	■ AUTOMATIC	Sellado de hashes y logs en almacenamiento inmutable de auditoría.